Procedimiento de acceso a servidores con credenciales temporales

Empresa: TechRetail
Versión: 1.0
Fecha: Septiembre 2025

---

1. Objetivo

Establecer un proceso seguro y auditable para otorgar, usar y revocar **credenciales temporales** de acceso a servidores (SSH/RDP) en la infraestructura de TechRetail, minimizando riesgos y garantizando trazabilidad.

---

2. Alcance

Aplica a todo personal técnico (Desarrollo, Operaciones, Soporte) y contratistas que requieran acceso temporal a servidores de **producción, preproducción** o **entornos internos**. No cubre accesos a aplicaciones SaaS con gestión propia.

---

3. Definiciones

- **Credencial temporal:** credencial (usuario/clave, token o llave SSH) con duración limitada y permisos acotados.
- **Justificación:** motivo técnico o de negocio que fundamenta la solicitud.
- **Owner:** responsable del sistema/servicio que autoriza el acceso.
- **Vault:** sistema seguro de gestión de secretos (ej. HashiCorp Vault, Azure Key Vault).

---

4. Principios de seguridad

1. Mínimo privilegio: permisos solo necesarios para la tarea.
2. Expiración automática: credenciales con TTL (time-to-live).
3. Registro (audit logs): todas las sesiones quedan registradas.
4. Aprovisionamiento centralizado: uso de vault o IAM para generación y distribución.

5. Prohibido el uso de cuentas compartidas permanentes; las temporales son individuales.

---

5. Roles y responsabilidades

- **Solicitante:** quien requiere acceso; debe completar la solicitud con justificación, tiempo y alcance.
- **Owner del servicio:** revisa y aprueba (o rechaza) la solicitud.
- **Soporte/Infraestructura:** implementa la credencial en el vault y configura la expiración; habilita el logging.
- **Seguridad/Compliance:** revisa accesos críticos y realiza auditorías periódicas.

---

6. Flujo paso a paso

6.1 Solicitud

1. El solicitante abre un ticket en el **portal de solicitudes** (ej. Jira/ServiceNow) con:
    - Sistema/servidor objetivo (hostname/IP).
    - Tipo de acceso (SSH, RDP, otros).
    - Usuario temporal requerido (si aplica).
    - Duración solicitada (máx. 8 horas por defecto; excepciones justificadas).
    - Justificación técnica detallada.
    - Hora/fecha de inicio y fin deseadas.
2. Adjuntar screenshot o comando que será ejecutado si aplica.

6.2 Aprobación

1. El **Owner** revisa la solicitud en un plazo acordado (ej. 2 horas) y decide: Aprobar / Rechazar / Solicitar más información.
2. En caso de aprobación, Owner añade condiciones si son necesarias (horario, IP fuente, restricciones de comandos).

6.3 Generación de credencial

1. Soporte/Infraestructura genera la credencial temporal mediante el **Vault** o sistema de IAM. Recomendaciones:
    - Para SSH: generar llave pública/privada con TTL o crear usuario con clave aleatoria y TTL.
    - Para RDP: crear usuario temporal en AD con expiración o generar contraseña temporal.

2. La credencial se almacena en el Vault y se entrega al solicitante mediante un canal seguro (no por correo sin cifrar).
3. El Vault debe registrar: quién generó la credencial, a quién fue entregada y su TTL.

6.4 Uso y monitoreo

1. El solicitante se conecta usando la credencial temporal; todas las conexiones deben pasar por un **jump host / bastion** con registro de sesiones (auditoría).
2. Habilitar grabación de sesión o registro de comandos (auditd, session recording) para accesos a producción.
3. Soporte/Infraestructura verifica logs y estado si se detecta comportamiento anómalo.

6.5 Cierre y revocación

1. Al terminar la tarea o al vencimiento del TTL, la credencial se revoca automáticamente desde el Vault.
2. El solicitante confirma cierre del ticket con evidencia (logs, outputs, pantallazos).
3. Owner y Soporte revisan registros, validan que no haya actividad pendiente y marcan la solicitud como completada.

---

7. Reglas y límites recomendados

- Duración por defecto: **máx. 8 horas**. Solicitudes de >8 horas requieren aprobación de Manager de Infraestructura y Security.
- No se permite extender credenciales sin nueva solicitud formal.
- Para tareas críticas en producción, se exige presencia de **segundo operador** (pair control) o revisión post-acción.
- Acceso root/administrador: usar `sudo` desde cuenta temporal; evitar login directo como `root` cuando sea posible.

---

8. Implementación técnica (ejemplos)

8.1 Ejemplo: SSH temporal con Vault (conceptual)

- Generar credencial temporal en Vault (TTL 8h) que cree un usuario en los servidores vía la integración SSH-CA o inyecte llave pública con expiración.
- Ejemplo conceptual (no es comando real, depende de la implementación Vault):

```
vault write ssh/creds/techretail-role \
    ip=10.1.2.3 \
    ttl=8h \
```

```
valid_principals="juan.perez"
```

- El usuario recibe la llave privada o cadena temporal para autenticar.

8.2 Ejemplo: RDP temporal vía AD

- Soporte crea cuenta en AD con `expiresOn` programado y la agrega al grupo necesario.
- Comando PowerShell (ejemplo conceptual):

```
New-ADUser -Name "temp_juan_perez" -SamAccountName "temp.juanp" -
AccountPassword (ConvertTo-SecureString "P@ssW0rdTmp!" -AsPlainText -
Force) -Enabled $true
Set-ADAccountExpiration -Identity temp.juan_p -DateTime (Get-
Date).AddHours(8)
Add-ADGroupMember -Identity "RDP-Users" -Members temp.juan_p
```

(La organización debe usar scripts parametrizados y seguros; evitar contraseñas en texto plano.)

8.3 Ejemplo: conexión via bastion (SSH)

- El usuario se conecta al bastion; el bastion registra y redirige la sesión:

```
ssh -i /path/to/temp_key -o ProxyCommand="ssh -W %h:%p
bastion.techretail.com" juan.perez@server-prod-01.techretail.com
```

---

9. Registro y auditoría

- Todas las solicitudes y actividades se deben registrar en: ticketing system, Vault logs, bastion logs, herramienta de SIEM.
- Retener logs por lo menos **12 meses** (o según políticas regulatorias aplicables).
- Revisiones periódicas: Security hará revisiones trimestrales de accesos temporales a producción.

---

10. Excepciones y manejo de incidentes

- En caso de uso no autorizado o sospecha de compromiso, suspender inmediatamente la cuenta y revocar credenciales; abrir un **incidente de seguridad** y notificar a Security y Management.
- Si la credencial no se revoca automáticamente por error, Soporte debe forzar la revocación y documentar la causa.

---

11. Checklist previo a la aprobación (para Owners)

- ¿La justificación es clara y necesaria?
- ¿La duración solicitada es la mínima necesaria?
- ¿Se emplearán controles de monitoreo (bastion, grabación)?
- ¿Se restringen IPs de origen si es posible?
- ¿Se documentará la actividad y se entregarán evidencias al cierre?

---

12. Buenas prácticas para solicitantes

- Preparar scripts y comandos antes de solicitar acceso (minimizar tiempo conectado).
- Usar cuentas personales temporales (no compartir).
- No dejar procesos ni credenciales en servidores tras finalizar.
- Entregar evidencia del trabajo realizado (logs, outputs) en el ticket de cierre.

---

13. Formación y sensibilización

- Entrenar a personal en el uso correcto de accesos temporales y en la cultura de mínimo privilegio.
- Simulacros de rotura de credenciales y revocación (exercises) cada 6 meses.

---

14. Contacto y soporte

- **Soporte Infraestructura:** soporte-infra@techretail.com — Ext. 9900
- **Equipo de Seguridad:** security@techretail.com — Ext. 9910
- **Portal de solicitudes (ticketing):** https://servicedesk.techretail.com